

IT/IS Auditing Question Paper – Set 2

Q.No.1. Which of the following is the major factor that affects the decision about performing an audit in an organization?

- a) Purpose
- b) Duration
- c) Budget
- d) Tools used

Q.No.2. Which of the following is the major factor affecting results of internal audits?

- a) Performed by the internal employees
- b) Lack of resources and finance
- c) Internal employee relationships
- d) Lack of professional capabilities.

Q.No.3 Which control classification attempts to repair the impact of a threat?

- a) Preventive
- b) Detective
- c) Deterrent
- d) Corrective

Q.No.4 Define Internal Controls?

- a) Control Tools used to detect risks
- b) Ensures proper functioning of processes within the company
- c) Defines the efficient Audit procedures
- d) Process in the Audit Planning

Q.No.5. Which is not an information security threat?

- a) Computer assisted Fraud
- b) Viruses
- c) Poverty
- d) Hacking

Q.No.6 What are the types of Internal Controls

- a) Asses, Remove and Protect
- b) Analyze, Design Process, Implement
- c) Qualitative and Quantitative
- d) Preventive, Detective, Reactive

Q.No.7 Which of the following is the best way for an auditor to determine the effectiveness of a security awareness and training program?

- a) Interview a sample of employees
- b) Review the security training program
- c) Interview the training program developers
- d) Review the security reminders to employees

Q.No.8 Reactive Internal Control is also called as

- a) Preventive Control
- b) Proactive Control
- c) Corrective Control
- d) Detection Control

Q.No.9 Logging all activities for later analysis is a

- a) Corrective Control
- b) Preventive Control
- c) Detective Control
- d) Proactive Control

Q.No.10 As an auditor you visit an organization for auditing and observe following things. Which of the following can be a threat for the organization?

- a) You did not find any important documents lying on the desk of any employee
- b) You observed that the entire campus is under video surveillance and regularly monitored
- c) You observed that old paper records were dumped into the UPS room and the room was hot and a lot of dust was accumulated on the records.
- d) You observed the visitor book just collects visitor name and mobile number and no ID proof of the visitor is checked

Q.No.11 Which of the following is the ideal Audit team reporting structure

- a) CFO/CEO, IT Audit Team
- b) CFO/CEO, IT Audit Committee, Director of Audits, Audit Manager, Audit Team
- c) IT Audit Committee, Director of Audits, Audit Manager
- d) Employees, Internal Audit team

Q.No.12 Which are the following are roles of System Administrator?

- a) Create & Implement Access Control Policies
- b) Employing security persons to guard resources
- c) Enable and Archive logs
- d) None of the above

Q.No. 13 -----Internal Control does not prevent errors from occurring, but provides systematic way to detect and correct the situation

- a) Proactive Control
- b) Detective Control
- c) Preventive Control
- d) **Corrective Control**

Q.No.14 Which are the activities done during Audit Planning?

- a) Field Work, Evaluation and Testing
- b) Confirmation of planned actions, Audit Response verification
- c) **Internal Control questionnaire, Audit scopes, Objectives**
- d) Communication, Audit findings, Assessment results

Q.No. 15 Which of the following is not a Best Practice in securing a web server?

- a) Up-to-date Web server
- b) **Run all possible services**
- c) Up-to-date OS
- d) Enable Logging

Q.No. 16 A method of evaluating the security of a computer system or network by simulating an attack by a hacker is called as?

- a) Incident Test
- b) Security Test
- c) Network Test
- d) Penetration Test

Q.No. 17 As an auditor you require to check if the antivirus is installed on all the computers and is properly updated. There are almost 2000 computers in the organization. Which of the following method you will choose during auditing?

- a) You will scan all 2000 computers to verify the requirement
- b) You will scan only those computers which are critical to the organization
- c) You will scan only those computers which are less critical and rarely used
- d) You will select some critical systems and some rarely used systems to scan

Q.No. 18 Which of this data gathering technique is most important in auditing?

- a) Review earlier audit reports
- b) Interview employees based on audit questionnaire
- c) Use various tools for system auditing
- d) Review documents like policies, old audit reports etc.

Q.No. 19 Software Change controls, access controls, backup and recovery are examples of -----

- a) Risk Management
- b) Risks
- c) Internal Controls
- d) Assets of organization

Q.No.20 Identify the activities of Audit Assessment Phase.

- a) Identify, Remove and Restore
- b) Accept, Mitigate, Transfer
- c) Fieldwork, Evaluation, Testing
- d) Analyze, Resolve and Restore

Q.No. 21 Identify the outcome of Audit Planning Phase

- a) Meeting, Scope, Objectives, Questionnaire, Plan and Checklist
- b) Testing, Listing the audit findings, reporting
- c) Testing, Evaluation and Eliminating the risks
- d) Meeting, Scope and Testing.

Q.No. 22 Which of the following is not a port scanner

- a) NMAP
- b) SuperScan
- c) Nessus
- d) dig

Q.No. 23 Select the best option which describes Risk Management:

- a) Identifying Risks
- b) Treating Risks
- c) Analyzing
- d) All of the above

Q.No.24. Windows Logs include:

- a) Application (program) events
- b) Security-related events
- c) System events.
- d) All of the above

Q.No.25. Consider an Audit Issue - Developers have direct access to update production code. As an auditor what would be your recommendation

- a) Ensure customer data is encrypted
- b) Review the access rights
- c) Allow the database management to the local administrator only.
- d) Proper software change controls to be defined and implemented

Q.No. 26 If an Auditor wants to express an opinion, then he should have

- a) Necessary qualification
- b) Audit Evidence
- c) Audit Recommendation
- d) Audit questionnaire

Q.No. 27 Which of the following best defines Audit Sampling

- a) Take samples for work
- b) Select only few projects in an organization
- c) Applying audit procedures to less 100% items inside a relevant population
- d) Choose all possible samples and perform audit process

Q.No. 28 Consider an Audit Issue - The default umask on the server is set to 000.
As an Auditor what would be your recommendation

- a) Set umask to 000 on all critical servers
- b) Remove umask on all critical servers
- c) Raise a security issue on all critical servers
- d) Set umask 027 on all critical servers

Q.No. 29 Buying an insurance for a company is a

- a) Risk acceptance approach
- b) Risk Transfer approach
- c) Process of identifying the scape goat
- d) Risk Mitigation approach

Q.No. 30 Identify the service that helps to setup firewall in Linux?

- a) iptables
- b) ypserv
- c) ypbind
- d) xinetd

Q.No.31 Which of the following is basic Risk Management Process?

- a) Risk Analysis, Develop Plan, Take Action, Measure Results
- b) Risk Analysis, Mitigate and Report
- c) Risk identification, Resolving and Documenting
- d) Risk Analysis, Develop Plan and Mitigate it

Q.No. 32 What is Event ID in Windows?

- a) Tool to identify events
- b) uniquely identifiable events that a Windows computer can encounter
- c) Security events have EventID
- d) Critical events have EventID

Q.No. 33 When is the Audit Exit Meeting conducted?

- a) During Assesment phase to tell the issues to the team
- b) During Reporting phase
- c) No exit meetings are conducted during any phase of Audit
- d) During Planning phase

Q.No 34 Which of the following is true about the qualitative risk analysis?

- a) It uses ratings such as High, Medium, and Low to tag the assets
- b) It uses terms like Single Loss Expectancy, Safeguard Value etc.
- c) It uses the cost of the assets
- d) It uses mathematical formulas to calculate the loss due to a risk

Q.No 35 Which of the following is not true about the quantitative risk analysis method?

- a) It uses the cost of the assets
- b) It uses ratings such as High, Medium, and Low to tag the assets
- c) It uses mathematical formulas to calculate the loss due to a risk
- d) It uses terms like Single Loss Expectancy, Safeguard Value etc.

Q.No. 36 ISO 27001:2005 is a

- a) Process
- b) Procedure
- c) Standard
- d) Best Practice

Q.No. 37 Which of the following is the most important factor according to ISO 27001 for effective implementation of Information Security Management System (ISMS)?

- a) Formation of a Risk analysis team
- b) Active support from the top management
- c) Formation of an internal audit team
- d) Proper documentation of all ISMS activities

Q.No. 38 Which of the following phase cycle approach is described by ISO27001 for effective implementation of ISMS within an organization?

- a) Plan-Do-Check-Act
- b) Plan-Act-Check-Do
- c) Act-Do-Check-Plan
- d) Plan-Check-Do-Act

Q.No. 39 If Cost to replace a car is \$10,000 and probability of car loss is 0.10, then calculate Risk?

- a) Risk = \$10,000 / 0.10
- b) Risk = \$10,000 * 0.10
- c) Risk = \$10,000 + 0.10
- d) Risk = \$10,000 * 0.10 + \$10,000

Q.No. 40 Which of the following tool allows parsing and querying Logs using SQL statements?

- a) Log Scanner on Windows
- b) Log Parser on Windows
- c) Cat /var/log/messages
- d) Log server

